

VULNERABILITY ASSESSMENT REPORT

Web Application Penetration Test

Target	http://testfire.net
Application	AltoroMutual Online Banking Demo
Test Type	Black-Box Web Application Security Assessment
Scope	Cross-Site Scripting (XSS) & SQL Injection (SQLi)
Test Date	04 June 2026
Classification	CONFIDENTIAL
Report Version	v1.0 — Final

1
CRITICAL

2
HIGH

3
MEDIUM

0
LOW

0
INFO

6 vulnerabilities identified

CYBER SECURITY TASK 1

PREPARED BY SAM VIVEK 21 June 2026

TABLE OF CONTENTS

1. Executive Summary

2. Scope & Objectives

3. Methodology

3.1 Reconnaissance

3.2 Vulnerability Scanning

3.3 Manual Exploitation

3.4 Risk Evaluation

4. Tools Used

5. Identified Vulnerabilities

5.1 Cross-Site Scripting (XSS)

5.2 SQL Injection (SQLi)

6. Risk Classification

7. Evidence & Screenshots

7.1 Reflected XSS

7.2 Stored XSS

7.3 DOM-Based XSS

7.4 Error-Based SQL Injection

7.5 UNION-Based SQL Injection

7.6 Blind Boolean SQLi

8. Remediation Steps

9. Conclusion

1. EXECUTIVE SUMMARY

The assessment focused on **OWASP A03:2021 – Injection** and **OWASP A01:2021/A05:2021** related security weaknesses within the application layer environment.

ID	VULNERABILITY	SEVERITY	CVSS V3.1	OWASP
VA-001	DOM-Based XSS — `/default.aspx`	HIGH	8.8	A03:2021
VA-002	Reflected Cross-Site Scripting (XSS) — `/sendFeedback`	HIGH	6.1 - 8.8	A03:2021
VA-003	SQL Injection — `/doLogin`	CRITICAL	9.8	A03:2021
VA-004	Missing CSP Header — `/sitemap.xml`	MEDIUM	5.3	A05:2021
VA-005	Cross-Site Request Forgery (CSRF) — `/login.jsp`	MEDIUM	6.5	A01:2021
VA-006	Clickjacking — `/`	MEDIUM	6.5	A05:2021

DISCLAIMER: testfire.net is IBM's intentionally vulnerable demo — authorised for security testing.

2. SCOPE & OBJECTIVES

Target: http://testfire.net
Application: AltoroMutual Online Banking Demo
Test Date: 20-21 June 2026 | **Environment:** Internet-facing (authorised)

In-Scope Endpoints

ENDPOINT	METHOD	PARAMETER(S)	ATTACK TYPE
/default.aspx	GET	URL Fragment ('#fragment')	DOM-Based XSS
/sendFeedback	POST	comment, name	Reflected Cross-Site Scripting (XSS)
/doLogin	POST	uid, passw	SQL Injection (SQLi)
/sitemap.xml	GET	Response Header	Missing CSP HeaderPARA
/login.jsp	GET	Login Form	Cross-Site Request Forgery (CSRF)
/	GET	N/A	Clickjacking

Objectives

3. METHODOLOGY

Testing followed the **OWASP Testing Guide v4.2** and **PTES** across four structured phases:

3.1 Reconnaissance :

Passive crawl of testfire.net to catalogue all input parameters, HTTP methods, cookies, and form fields. Fingerprinting via response headers confirmed ASP.NET and Microsoft SQL Server backend.

3.2 Vulnerability Scanning :

Automated scanning with OWASP ZAP and Nikto. Results triaged manually to remove false positives before exploitation.

3.3 Manual Exploitation :

Hand-crafted payloads delivered via Burp Suite Repeater. Each payload escalated incrementally from basic injection through filter bypass to full proof-of-concept, with HTTP captures recorded at every stage.

3.4 Risk Evaluation :

Findings scored using CVSS v3.1 Base Score. Business impact including data exposure, authentication bypass, and regulatory risk factored into the final risk classification.



4. TOOLS USED

TOOL	VERSION	PURPOSE	CATEGORY
Burp Suite Community	2023.x	HTTP proxy, intercept, payload delivery	Proxy
OWASP ZAP	2.14	Automated scanning, spider crawl	Scanner
SQLMap	1.7.x	SQL injection detection and exploitation	Exploit
Firefox DevTools	125+	DOM inspection, JS debugging, cookies	Browser